Review 1

P01 IT Helpdesk

Kiểm soát truy cập và giám sát bảo mật

Group2

Hồ sơ v1.1 Draft, ngày 29 tháng 10 năm 2026

Đề xuất phạm vi và thiết kế để giảng viên góp ý

Phạm vi MVP

Nhóm chức năng	Yêu cầu
Tài khoản và danh mục	HD01–HD02
Ticket, xử lý và đóng/mở lại	HD03–HD10
SLA, tìm kiếm và dashboard	HD11–HD14

Employee, IT Staff, IT Manager và Admin

HD15 đánh giá hài lòng: Should, ngoài điều kiện MVP cốt lõi

Ngoài phạm vi: điều khiển máy từ xa, agent endpoint, Active Directory và SOC ngoài lab

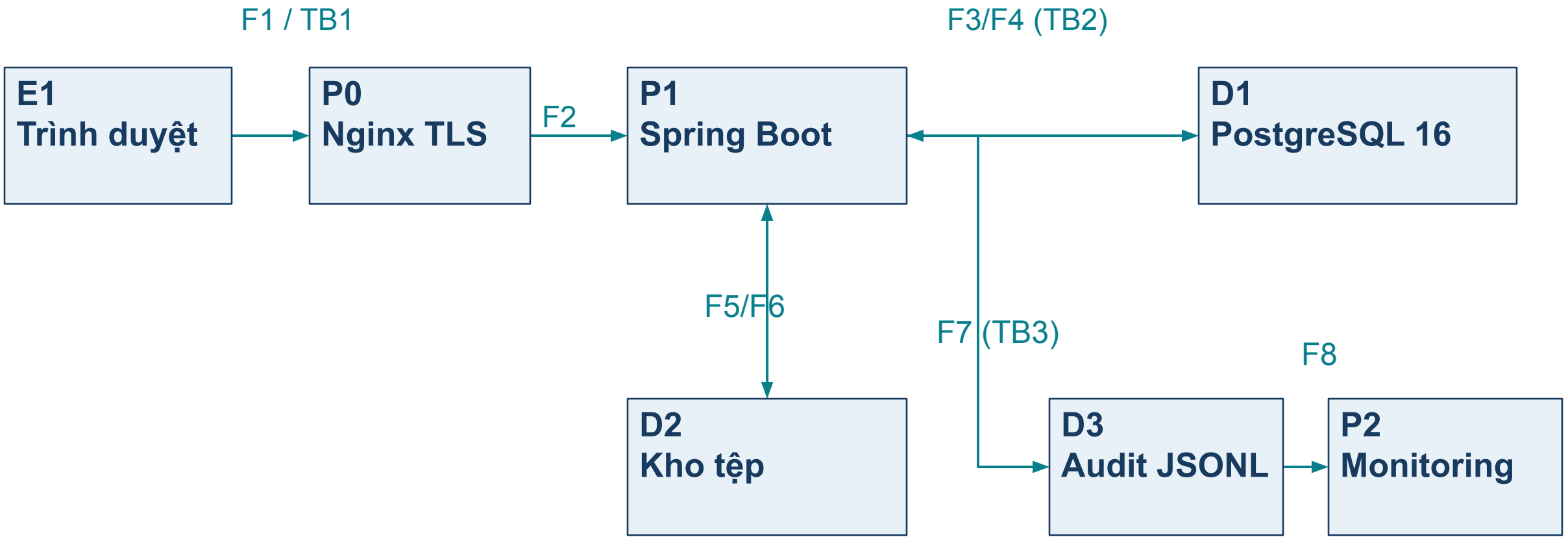
Quy trình nghiệp vụ

Quy trình	Luồng tóm tắt
P1 Tiếp nhận và xử lý	Tạo ticket, phân công, tiếp nhận, xử lý, nhập giải pháp, Resolved
P2 Theo dõi SLA	Worker 5 phút, nhãn gần hạn/quá hạn, Manager xem chi tiết và điều phối
P3 Đóng hoặc yêu cầu mở lại	Chủ ticket đóng khi Resolved hoặc gửi request PENDING để Manager duyệt

Theo UC-08: ticket giữ Resolved trong lúc yêu cầu PENDING

PC-02: SE cần đồng bộ BPMN, state Reopened và SLA sau mở lại trước khi chốt baseline

Kiến trúc và ranh giới tin cậy



Backend ghi JSONL, Monitoring đọc để phát hiện và cảnh báo

Thiết kế tham chiếu. Cấu hình deployment và lựa chọn công cụ còn chờ xác nhận

Threat model và kế hoạch kiểm thử

Nhóm rủi ro	Threat ID	Test chính
Tài khoản và token	TH-01, TH-08	SEC-TC-HD-02/08
Quyền ticket và role	TH-02, TH-04, TH-07	SEC-TC-HD-01/05/06
Tệp đính kèm	TH-05, TH-06	SEC-TC-HD-03
Audit và bảo vệ log	TH-03, TH-09	SEC-TC-HD-04/08
XSS và SQLi	TH-11, TH-12	SEC-TC-HD-07/08
Secrets	TH-10	SEC-TC-HD-08

12 mối đe dọa, 7 mã SR, 8 nhóm test và 12 dòng risk

EV-HD-21…28 là evidence dự kiến. Chưa chạy kiểm thử và chưa chấm residual risk

Ma trận quyền

Thao tác	Employee	IT Staff	Manager	Admin
Xem ticket	Own	Assigned + New chỉ xem	All	Chỉ đọc
Tạo ticket	Có	Không	Không	Không
Phân công	Không	Không	Có	Không
Đổi status	Không	Assigned	Không *	Không
Đóng ticket	Own, Resolved	Không	Resolved	Không
Tải byte tệp	Own	Theo phạm vi	All	Không *
User và role	Không	Không	Không	Có

*** Baseline SecRS §5 còn khác SDD. PC-03 chờ SE và Khánh chốt**

Kiểm token 401, phạm vi xem 404, quyền thao tác 403, rồi kiểm trạng thái 422

Quyết định cần chốt tại Review 1

Điểm	Nội dung	Phối hợp
PC-01	Cơ chế tải tệp, TTL và thu hồi URL	Nhi, Cường/Trí
PC-02	State Reopen và SLA sau mở lại	Trí, Cường, Khánh
PC-03	Quyền, mã lỗi và ghi chú nội bộ	Khánh, Cường/Trí
PC-04	Schema log, rule, tool và retention	Hoà, Backend, Nhi
PC-05	Mạng, TLS, ports, volume và backup	Nhi, Chính, Trí
PC-06	SE review các tham chiếu NFR/test đã sửa	Chính, Cường/Trí

GV góp ý và xác nhận phạm vi. Nhóm ghi quyết định, owner và hạn vào file 08

Chỉ chuyển Done khi đủ đầu ra và có xác nhận review thực tế